

Yêu cầu phi chức năng

Yêu cầu hiệu năng (Performance Requirements)

- **Thời gian phản hồi hệ thống**
 - o Trang chủ tải trong thời gian không quá 2 giây dưới điều kiện tải thông thường.
 - o Danh sách sản phẩm (hơn 50.000 bản ghi, có filter, phân trang) tải trong ≤ 2 giây.
 - o Tìm kiếm sản phẩm theo tên hoặc mã trả kết quả trong ≤ 1 giây.
 - o Trang thanh toán tải trong ≤ 2 giây; quy trình tạo đơn hàng hoàn tất trong ≤ 3 giây.
 - o API phổ biến (tìm kiếm, thêm sản phẩm, cập nhật trạng thái...) có thời gian phản hồi trung bình ≤ 1 giây.
- **Hiệu năng các nghiệp vụ chính**
 - o Cập nhật sản phẩm hoặc tồn kho đồng bộ theo thời gian thực với độ trễ < 1 giây.
 - o Cập nhật trạng thái giao hàng trong ≤ 2 giây.
 - o Truy vấn lịch sử đơn hàng của khách hàng (bao gồm trạng thái, sản phẩm, thời gian) với số lượng đơn hàng > 10.000 trong ≤ 1.5 giây.
 - o Tìm kiếm đơn hàng theo mã hoặc tên khách hàng thực hiện trong ≤ 1 giây.
- **Hệ thống gợi ý sản phẩm thông minh**
 - o Gợi ý sản phẩm dựa trên lịch sử mua hàng trả kết quả trong ≤ 0.5 giây.
 - o Hệ thống gợi ý hỗ trợ xử lý ổn định ở mức 10.000 yêu cầu mỗi giây (RPS), có khả năng tự động mở rộng (auto-scaling) để đáp ứng đến 50.000 RPS trong các sự kiện lớn (ví dụ Black Friday). Thời gian khởi tạo hạ tầng bổ sung không quá 3 phút.
- **Truy vấn và xuất báo cáo**

- Truy vấn báo cáo doanh thu theo ngày/tuần thực hiện trong ≤ 5 giây.
- Xuất dữ liệu tổng hợp ra file Excel hoặc CSV trong ≤ 10 giây, kể cả với tập dữ liệu lớn (>100.000 bản ghi).
- **Khả năng mở rộng và tính sẵn sàng**
 - Hệ thống hỗ trợ tối thiểu 10.000 người dùng đồng thời, với khả năng mở rộng ngang (horizontal scaling) thông qua container hoặc phân cụm (cluster).
 - Cơ sở dữ liệu có khả năng xử lý ít nhất 1.000 giao dịch mỗi phút mà không bị gián đoạn.
 - Thời gian hoạt động (uptime) đạt tối thiểu 99,9%/năm tương đương downtime không vượt quá 8.76 giờ/năm.
 - Thời gian phục hồi sau sự cố (RTO) không vượt quá 1 giờ.
 - Điểm khôi phục dữ liệu (RPO) không vượt quá 15 phút trong trường hợp có sự cố nghiêm trọng.
- **Tối ưu tài nguyên hệ thống**
 - Trong điều kiện tải thông thường:
 - CPU không vượt quá 70% trung bình trong 15 phút.
 - RAM không vượt quá 4GB trên mỗi máy chủ ứng dụng.
 - Hệ thống phải áp dụng nén và cache cho tài nguyên tĩnh (ảnh, JS, CSS...) để giảm thời gian tải và băng thông.
 - Tích hợp CDN (Content Delivery Network) để tối ưu hiệu suất truy xuất tệp tĩnh ở quy mô toàn quốc.

Yêu cầu về an toàn (Safety Requirements)

- **Bảo vệ dữ liệu và phục hồi sau sự cố**
 - Hệ thống phải tự động sao lưu toàn bộ dữ liệu quan trọng (sản phẩm, đơn hàng, tài khoản người dùng, cấu hình hệ thống) theo chu kỳ 24 giờ/lần.
 - Bản sao lưu phải được lưu trữ tại ít nhất hai vị trí vật lý độc lập, hoặc sử dụng dịch vụ cloud hỗ trợ phân vùng dữ liệu (multi-zone).

- Quy trình khôi phục dữ liệu cần được mô tả rõ ràng, có thể thực hiện trong thời gian tối thiểu và đã được kiểm thử định kỳ.
- Trong trường hợp có lỗi nghiêm trọng, hệ thống phải hỗ trợ khôi phục trạng thái hoạt động từ bản sao lưu gần nhất một cách an toàn và hiệu quả.
- **Đảm bảo tính sẵn sàng và hoạt động liên tục (Availability and Continuity)**
 - Hệ thống cần đảm bảo thời gian hoạt động tối thiểu là 99.5% hàng tháng, bao gồm cả thời gian bảo trì định kỳ.
 - Cần triển khai cơ chế dự phòng (redundancy) cho máy chủ ứng dụng, cơ sở dữ liệu và dịch vụ quan trọng, thông qua các kỹ thuật như load balancing, failover, hoặc cụm máy chủ (cluster).
 - Khi xảy ra lỗi tại một thành phần, hệ thống phải duy trì hoạt động ở mức tối thiểu nhờ cơ chế giảm chức năng có kiểm soát (graceful degradation).
- **Hạn chế rủi ro do thao tác người dùng**
 - Các hành động có rủi ro cao như xóa dữ liệu, hoàn tiền, cập nhật hàng loạt cần có xác nhận hai bước (modal xác nhận và nhập mã xác thực nếu cần).
 - Giao diện người dùng cần hiển thị cảnh báo rõ ràng, biểu tượng cảnh báo và màu sắc nổi bật đối với các thao tác có khả năng ảnh hưởng đến dữ liệu hoặc trạng thái hệ thống.
 - Tài khoản người dùng cần được phân quyền chi tiết để ngăn ngừa thao tác không phù hợp (ví dụ: giới hạn quyền xóa cho admin cấp cao).
- **Ghi nhận và xử lý lỗi hệ thống**
 - Hệ thống cần ghi lại đầy đủ nhật ký sự kiện (event logs), bao gồm lỗi ứng dụng, lỗi cơ sở dữ liệu, lỗi mạng và các hành động quản trị quan trọng.
 - Nhật ký lỗi phải hỗ trợ phân loại mức độ nghiêm trọng (INFO, WARNING, ERROR, CRITICAL) và thời gian chính xác.

- Cần có cơ chế phát hiện lỗi tự động và gửi cảnh báo qua email/SMS đến bộ phận kỹ thuật hoặc quản trị hệ thống.
- Người dùng phải có phương tiện báo lỗi nhanh chóng, ví dụ: nút “Báo lỗi” hoặc “Gửi phản hồi” trên giao diện.
- **Kiểm thử an toàn hệ thống trước khi triển khai**
 - Trước mỗi lần triển khai hoặc nâng cấp hệ thống, cần thực hiện:
 - Kiểm thử hồi quy (Regression Testing) để đảm bảo các chức năng hiện có không bị ảnh hưởng.
 - Kiểm thử hiệu suất (Performance Testing), bao gồm kiểm thử tải (Load Testing) và kiểm thử sức chịu đựng (Stress Testing).
 - Có môi trường staging riêng để kiểm thử trước khi triển khai lên hệ thống chính thức.
- **Bảo vệ giao dịch tài chính**
 - Các giao dịch thanh toán trực tuyến cần có cơ chế xác thực đa lớp (ví dụ: OTP, mã QR, mã hóa token).
 - Hệ thống cần tích hợp tính năng phát hiện hành vi bất thường hoặc gian lận giao dịch (ví dụ: số lần thanh toán lặp bất thường, thay đổi địa chỉ giao hàng nhiều lần).
 - Quy trình hoàn tiền cần được ghi nhận đầy đủ và minh bạch, có xác nhận từ cả người dùng và quản trị viên, đồng thời được lưu vào lịch sử giao dịch.
- **Tuân thủ quy định pháp luật và chính sách bảo mật**
- Hệ thống phải tuân thủ các quy định hiện hành liên quan đến:
 - Luật An toàn thông tin mạng
 - Luật Bảo vệ người tiêu dùng
 - Luật Thương mại điện tử
- Thông tin người dùng phải được bảo vệ theo nguyên tắc bảo mật dữ liệu cá nhân (ví dụ: mã hóa, không lưu trữ mật khẩu dạng rõ văn bản).
- Cần xây dựng chính sách bảo mật và chính sách quyền riêng tư rõ ràng, công khai trên hệ thống và cập nhật theo thời gian.

Yêu cầu về an ninh bảo mật (Security Requirements)

- Xác thực và phân quyền người dùng

- Hệ thống phải yêu cầu người dùng đăng nhập bằng tài khoản và mật khẩu được băm an toàn (ví dụ: SHA-256 hoặc bcrypt).
- Tài khoản quản trị viên (admin) và người dùng có quyền cao cần được bảo vệ bằng xác thực hai yếu tố (2FA), ví dụ: mã OTP gửi qua email, SMS hoặc ứng dụng xác thực.
- Áp dụng chính sách mật khẩu mạnh: tối thiểu 8 ký tự, có chữ hoa, chữ thường, số và ký tự đặc biệt.
- Tài khoản sẽ bị khóa tạm thời sau 5 lần đăng nhập sai liên tiếp nhằm chống tấn công brute-force.
- Mỗi người dùng phải được gán một vai trò cụ thể; hệ thống áp dụng mô hình phân quyền theo vai trò (RBAC) để kiểm soát truy cập đến từng chức năng.

- Bảo vệ dữ liệu và bảo mật truyền thông

- Mọi tương tác giữa người dùng và hệ thống (đăng nhập, thanh toán, cập nhật dữ liệu) đều phải được mã hóa qua giao thức HTTPS sử dụng TLS 1.3.
- Dữ liệu nhạy cảm như thông tin cá nhân, lịch sử giao dịch, cấu hình hệ thống phải được mã hóa trong cơ sở dữ liệu bằng thuật toán mạnh như AES-256.
- Không lưu trữ thẻ thanh toán hoặc mã CVV trong hệ thống. Thay vào đó, tích hợp thanh toán qua các cổng uy tín (VNPay, MoMo, ZaloPay, v.v.) đáp ứng tiêu chuẩn PCI DSS.
- Khi hiển thị thông tin nhạy cảm (như số thẻ), cần thực hiện masking, chỉ hiển thị một phần (ví dụ: **** * 1234).
- Log hệ thống và nhật ký truy cập phải được mã hóa và chỉ có thể đọc bởi người có quyền.

- Ngăn chặn tấn công mạng và lỗ hổng bảo mật

- Kiểm tra đầu vào người dùng kỹ lưỡng để ngăn các cuộc tấn công như:

- SQL Injection: lọc và escape dữ liệu đầu vào
- XSS (Cross-site Scripting): mã hóa output
- CSRF (Cross-site Request Forgery): sử dụng token CSRF trong các form
- Hệ thống cần giới hạn tần suất truy cập (rate limiting) để phòng chống tấn công từ chối dịch vụ (DDoS) hoặc spam.
- File người dùng tải lên phải được giới hạn định dạng (ví dụ: chỉ .jpg, .png, .pdf), giới hạn kích thước, và kiểm tra mã độc bằng phần mềm diệt virus.
- Giao diện quản trị chỉ được truy cập từ các địa chỉ IP được định danh (IP whitelist).
- **Giám sát và phản ứng sự cố**
 - Hệ thống phải ghi nhật ký đầy đủ tất cả các hành động quan trọng: đăng nhập, sửa dữ liệu, thay đổi quyền, lỗi hệ thống, truy cập API.
 - Hệ thống cần phát hiện và cảnh báo khi có hành vi bất thường như:
 - Đăng nhập từ nhiều vị trí địa lý khác nhau cùng lúc
 - Số lượng truy vấn API bất thường
 - Cố gắng truy cập khu vực không được cấp quyền
 - Có công cụ hoặc cơ chế tự động gửi cảnh báo (qua email, webhook hoặc hệ thống quản trị log tập trung như ELK/Graylog).
 - Cần duy trì log ít nhất 6 tháng, có cơ chế backup định kỳ và truy vết khi có sự cố.
- **Bảo trì, cập nhật và quản trị an toàn**
 - Các máy chủ, hệ điều hành và dịch vụ hệ thống phải được cập nhật bản vá bảo mật định kỳ, đặc biệt là khi có lỗ hổng CVE nghiêm trọng.
 - Thư viện, framework bên thứ ba (ví dụ: Node.js, Laravel, React) phải được kiểm tra định kỳ để đảm bảo không tồn tại lỗ hổng đã biết.

- Chỉ người có quyền cao nhất (DevOps, Admin cấp cao) mới được truy cập trực tiếp hệ thống sản xuất (production).
- Toàn bộ thao tác trên máy chủ, CSDL và hệ thống CI/CD cần được ghi log và có xác thực đầy đủ.
- **Tuân thủ quy định pháp luật và chuẩn bảo mật**
 - Hệ thống phải tuân thủ các tiêu chuẩn và quy định sau:
 - GDPR hoặc Nghị định 13/2023/NĐ-CP (Việt Nam) về bảo vệ dữ liệu cá nhân
 - PCI DSS đối với các giao dịch tài chính
 - ISO/IEC 27001 nếu có áp dụng trong doanh nghiệp
 - Khi có vi phạm dữ liệu (data breach), cần có quy trình phản hồi gồm:
 - Thông báo cho người dùng bị ảnh hưởng trong vòng 72 giờ
 - Cô lập nguyên nhân, vá lỗi và báo cáo cho bên liên quan
 - Cần công khai chính sách bảo mật và quyền riêng tư (Privacy Policy) minh bạch trên website.

Các thuộc tính chất lượng phần mềm

- **Tính rõ ràng và nhất quán (Clarity and Consistency)**
 - Ngôn ngữ sử dụng trong tài liệu yêu cầu phần mềm (SRS) phải rõ ràng, chính xác, tránh các mô tả mơ hồ như “dễ sử dụng”, “nhanh”, “tốt” nếu không có tiêu chí đo lường cụ thể.
 - Mỗi yêu cầu chức năng hoặc phi chức năng cần được trình bày dứt khoát, sử dụng câu chủ động, đơn nghĩa và có cấu trúc ngữ pháp rõ ràng.
 - Không được tồn tại mâu thuẫn giữa các yêu cầu. Nếu có các yêu cầu xung đột, cần chỉ rõ điều kiện ưu tiên hoặc quy tắc xử lý (ví dụ: phân quyền theo vai trò người dùng).
 - Thuật ngữ chuyên môn phải được định nghĩa rõ ràng trong mục “Thuật ngữ và từ viết tắt”. Việc sử dụng cần thống nhất xuyên suốt tài liệu để tránh hiểu sai.

- **Cấu trúc hệ thống và tổ chức tài liệu hợp lý (Structural Soundness and Logical Organization)**
 - Kiến trúc phần mềm cần tuân theo nguyên lý thiết kế phân lớp (Layered Architecture), có thể áp dụng mô hình MVC, Hexagonal hoặc Microservices nếu phù hợp.
 - Mỗi chức năng chính (module) của hệ thống phải được mô tả riêng biệt và có ràng buộc rõ ràng về dữ liệu, giao tiếp, và xử lý lỗi.
 - Cấu trúc tài liệu cần phản ánh đúng luồng phát triển phần mềm: từ yêu cầu nghiệp vụ → phân tích hệ thống → thiết kế chức năng → kiểm thử và triển khai.
 - Tên các thành phần hệ thống (lớp, module, API, CSDL) cần thống nhất theo chuẩn đặt tên đã được định nghĩa (nên kèm theo “Quy ước đặt tên”).
- **Khả năng bảo trì và mở rộng (Modifiability and Extensibility)**
 - Thiết kế phần mềm cần hướng đến nguyên lý “mở rộng được nhưng không sửa đổi” (Open-Closed Principle), cho phép thêm mới chức năng mà không gây ảnh hưởng tới các phần đang hoạt động.
 - Các module phải có mức độ liên kết nội bộ cao (high cohesion) và liên kết ngoài thấp (low coupling) để giảm ảnh hưởng khi sửa đổi.
 - Cấu trúc cơ sở dữ liệu và hệ thống API phải cho phép mở rộng phạm vi ứng dụng trong tương lai (ví dụ: hỗ trợ nhiều chi nhánh, đơn vị vận hành).
 - Toàn bộ thay đổi phần mềm cần được quản lý bằng hệ thống quản lý phiên bản (version control), kèm theo log thay đổi và lý do cập nhật.
- **Tính đầy đủ (Completeness)**

- Tài liệu yêu cầu phải liệt kê đầy đủ tất cả các chức năng chính và phụ của hệ thống, bao gồm cả các tình huống biên và điều kiện ngoại lệ.
- Mỗi tính năng yêu cầu phải được mô tả theo mô hình chuẩn gồm: Mục tiêu – Đầu vào – Xử lý – Đầu ra – Điều kiện lỗi – Phản hồi.
- Các yêu cầu phi chức năng như bảo mật, hiệu năng, khả năng tương thích, backup, v.v., cũng cần được trình bày chi tiết trong mục riêng.
- Không được tồn tại phần chức năng "ngầm hiểu" không ghi trong tài liệu, và cũng không được có yêu cầu không thực tế hoặc chưa được xác minh từ phía nghiệp vụ.
- **Khả năng truy xuất nguồn gốc (Traceability)**
 - Mỗi yêu cầu phải có mã định danh duy nhất (ví dụ: FR-01, NFR-03) để dễ dàng tham chiếu và kiểm tra xuyên suốt vòng đời phần mềm.
 - Cần liên kết giữa yêu cầu nghiệp vụ, yêu cầu chức năng, thiết kế hệ thống, test case, và kết quả kiểm thử để đảm bảo toàn bộ chuỗi truy vết (end-to-end traceability).
 - Phải có bảng đối chiếu giữa các yêu cầu và người đưa ra yêu cầu, thời gian ghi nhận, trạng thái (pending/approved/implemented).
 - Lịch sử thay đổi yêu cầu phải được lưu trữ rõ ràng với thông tin người sửa, thời điểm, nội dung thay đổi và lý do.
- **Tính khả dụng (Usability)**
 - Giao diện người dùng cần thiết kế theo nguyên tắc UX/UI hiện đại, phù hợp với người dùng không chuyên, đảm bảo:
 - Cấu trúc menu rõ ràng, trực quan
 - Hạn chế thao tác thừa
 - Cung cấp phản hồi ngay lập tức cho thao tác người dùng (thành công/thất bại)
 - Hệ thống phải hỗ trợ thao tác bàn phím và thiết bị di động.

- Ngôn ngữ hiển thị phải phù hợp với đối tượng sử dụng (ít nhất hỗ trợ tiếng Việt). Có thể mở rộng để hỗ trợ đa ngôn ngữ (i18n).
- Khi xảy ra lỗi, hệ thống cần đưa ra thông điệp rõ ràng, chỉ dẫn cách khắc phục, và không làm mất dữ liệu đang nhập.
- **Tính cần thiết và tính hợp lý (Necessity and Justifiability)**
 - Mỗi yêu cầu phải có nguồn gốc rõ ràng (nhiệm vụ, quy định pháp lý, yêu cầu khách hàng, v.v.) và được phân loại theo mức độ ưu tiên:
 - Bắt buộc
 - Nên có
 - Có thể có
 - Không đưa vào tài liệu các yêu cầu tùy hứng, không rõ lý do hoặc vượt quá phạm vi dự án hiện tại.
 - Cần có quy trình xét duyệt và phê duyệt yêu cầu (approval flow) trước khi triển khai.
- **Tính dễ hiểu và dễ áp dụng (Understandability)**
 - Tài liệu yêu cầu phải có sơ đồ minh họa (UML, flowchart, ERD) để thể hiện rõ mối quan hệ và luồng xử lý.
 - Mỗi đoạn tài liệu dài nên có mô tả tổng quát đầu đoạn, ví dụ minh họa nếu cần thiết, và chú thích rõ ý nghĩa các từ viết tắt hoặc kỹ thuật.
 - Đối với các phần liên quan đến nghiệp vụ phức tạp, cần có mục “Giải thích nghiệp vụ” để người kỹ thuật dễ hiểu và lập trình đúng ý định.
- **Tính kiểm chứng được (Verifiability)**
 - Mỗi yêu cầu phải có tiêu chí kiểm thử rõ ràng (measurable), có thể đánh giá thông qua kiểm thử thủ công hoặc tự động.
 - Yêu cầu cần liên kết với test case cụ thể và tiêu chí đánh giá (pass/fail).
 - Trong giai đoạn kiểm thử, hệ thống phải có log chi tiết, khả năng chụp lỗi (error snapshot) để hỗ trợ xác minh.

- Cần mô tả các công cụ sẽ được sử dụng để kiểm tra (ví dụ: Postman cho API, Selenium cho UI, JMeter cho hiệu năng...).
- **Tính chính xác (Correctness)**
 - Hệ thống phải thực hiện đúng theo yêu cầu nghiệp vụ và các quy trình đã được mô tả trong tài liệu.
 - Mọi thao tác xử lý dữ liệu phải tuân theo trình tự nghiệp vụ, không bỏ sót, không sai logic.
 - Các sai lệch (bug, logic conflict) cần được phát hiện sớm trong giai đoạn kiểm thử và khắc phục triệt để trước khi triển khai chính thức.
 - Hệ thống cần có cơ chế xác thực tính đúng đắn qua nhiều tầng: validation đầu vào, kiểm tra nghiệp vụ, kiểm thử toàn diện.

Các quy tắc nghiệp vụ - Bussiness Rules

- **Tuân thủ quy trình nghiệp vụ bán hàng**
 - Hệ thống phải tuân thủ đầy đủ quy trình xử lý đơn hàng của siêu thị theo trình tự: Đặt hàng → Xác nhận đơn → Kiểm kho → Chuẩn bị hàng → Giao hàng → Thanh toán. Mỗi bước cần được ghi nhận trạng thái rõ ràng và nhất quán.
 - Không được xác nhận đơn hàng nếu:
 - Một trong các sản phẩm đã hết hàng hoặc số lượng tồn kho không đủ.
 - Sản phẩm chưa được định giá hợp lệ.
 - Khi khách hàng hủy đơn hàng trước giai đoạn vận chuyển, hệ thống phải:
 - Tự động hoàn kho cho các sản phẩm tương ứng.
 - Ghi log thao tác cho mục đích truy vết và báo cáo sau này.
- **Áp dụng chính sách giá, khuyến mãi và thuế**
 - Giá bán của mỗi sản phẩm phải lớn hơn hoặc bằng giá nhập. Nếu không thỏa điều kiện này, hệ thống từ chối lưu thay đổi.

- Hệ thống chỉ cho phép một mã khuyến mãi duy nhất áp dụng cho mỗi đơn hàng. Nếu có nhiều mã, ưu tiên mã có mức giảm cao nhất hoặc theo chính sách cấu hình.
- Mã khuyến mãi có thể giới hạn:
 - Số lần sử dụng tổng/quý/người dùng
 - Danh mục sản phẩm áp dụng
- Tổng giá trị khuyến mãi không vượt quá 70% giá trị đơn hàng.
- Mọi giao dịch phát sinh thuế GTGT cần:
 - Ghi nhận mã số thuế (nếu khách là doanh nghiệp)
 - Tổng hợp báo cáo định kỳ theo định dạng của bộ phận tài chính
- **Quản lý đơn hàng và chính sách thanh toán**
 - Đơn hàng chưa được xử lý có thể hủy trong vòng 24 giờ kể từ khi đặt, sau thời điểm này chỉ có quản lý mới có quyền thao tác hủy.
 - Hoàn tiền chỉ áp dụng trong vòng 7 ngày sau khi giao hàng thành công và phải được ghi nhận lý do.
 - Hệ thống sẽ:
 - Tự động cập nhật tồn kho khi đơn hàng được xác nhận.
 - Gửi thông báo nhắc nhở thanh toán sau 12 giờ nếu đơn hàng chưa được thanh toán.
 - Tự động hủy đơn sau 24 giờ nếu vẫn chưa có thanh toán.
 - Phát hành hóa đơn điện tử ngay sau khi thanh toán thành công.
- **Quản lý khách hàng và điểm thưởng**
 - Mỗi khách hàng phải có email và số điện thoại duy nhất.
 - Hệ thống xếp hạng thành viên theo tổng giá trị mua hàng trong 12 tháng gần nhất.
 - Điểm thưởng:
 - Có thời hạn sử dụng là 12 tháng
 - Mỗi đơn hàng chỉ được sử dụng tối đa 50% giá trị bằng điểm

- Không hoàn lại điểm khi hủy đơn hàng nếu đơn đã được hoàn tiền.
- **Phân quyền theo vai trò và chức năng**
 - Hệ thống phải áp dụng mô hình phân quyền theo vai trò (RBAC) với quy định cụ thể:
 - Nhân viên kho: chỉ truy cập tồn kho, không xem thông tin giá, không thao tác đơn hàng.
 - Nhân viên bán hàng: tạo đơn, kiểm tra trạng thái đơn hàng, tra cứu sản phẩm, không thay đổi giá hoặc khuyến mãi.
 - Quản lý: duyệt đơn, xem báo cáo, chỉnh sửa khuyến mãi, phê duyệt đơn đặc biệt (>100 triệu), không truy cập phân quyền.
 - Quản trị viên hệ thống: cấu hình toàn hệ thống nhưng không được thao tác vào quy trình nghiệp vụ bán hàng.
- **Ràng buộc và giới hạn nghiệp vụ**
 - Một đơn hàng có tổng giá trị trên 100 triệu đồng bắt buộc phải được duyệt bởi quản lý cấp cao hoặc giám đốc.
 - Không cho phép xóa đơn hàng đã thanh toán; chỉ được tạo yêu cầu hoàn tiền hoặc điều chỉnh bằng hóa đơn bù trừ.
 - Tự động ẩn sản phẩm nếu sản phẩm đó không còn hàng trong vòng 60 ngày và không phát sinh giao dịch mới.
 - Không cho phép nhập tồn kho âm hoặc đặt hàng khi số lượng không đủ.
- **Quy định về báo cáo và lưu trữ dữ liệu**
 - Tất cả dữ liệu liên quan đến khách hàng, đơn hàng, tồn kho, giao dịch phải được lưu trữ tối thiểu 5 năm để phục vụ kiểm toán hoặc thanh tra.
 - Các báo cáo định kỳ (doanh thu, tồn kho, sản phẩm bán chạy...) phải được xuất dưới định dạng PDF hoặc Excel với cấu trúc do bộ phận tài chính quy định.

- Hệ thống hỗ trợ lọc báo cáo theo ngày, tuần, tháng, theo nhiều điều kiện kết hợp (kho, nhân viên, sản phẩm...).